

Alert Triage Methodology

Notes and example investigations

Overview

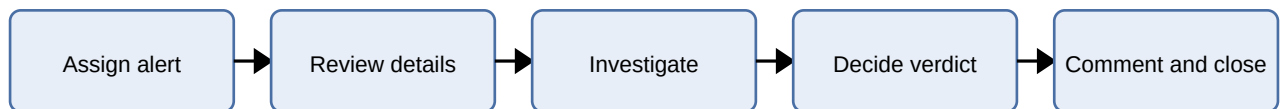
This report explains how I triage security alerts as a Level 1 (L1) SOC analyst. I learned the process while working through the TryHackMe SOC Level 1 learning path. To show how I apply it, I wrote four example alerts of my own and investigated each one.

Disclaimer

All alerts, users, hosts and companies in this report are fictional and were created by me. None of the examples come from TryHackMe rooms.

My Triage Process

I follow the same steps for every alert:



- Assign the alert to myself and move it to In Progress, so no other analyst works on it at the same time.
- Read the alert name, description and key details.
- Find out who or what is affected, such as the user, host or network, and check what happened before and after the alert.
- Decide if the activity is malicious (True Positive) or normal (False Positive).
- Write a comment with my evidence and verdict, then close or escalate the alert.

Questions I Ask

Question	Why it matters
Who or what is affected?	A finance laptop or a domain controller is higher risk than a test machine.
Is there a normal reason for this?	Many alerts are caused by normal work, backups or IT changes.
Where did it come from or go to?	A trusted service is very different from an unknown domain.
What started the process?	The parent process often shows how the activity began.
Does it match a known change?	IT change tickets can explain admin activity.

Example Investigations

Each example below is set at a fictional company called Northfield Logistics.

1. Multiple Failed Logins

Severity	Medium
Description	More than 30 failed logins for one account in 5 minutes.
Account	svc-backup
Source host	BKP-SRV-01
Failed attempts	42 in 2 minutes, then no more
Other context	The svc-backup password was changed the day before

A burst of failed logins can mean someone is guessing a password. But the attempts came from the backup server, which is where this service account is used. They started at the time the nightly backup task runs and stopped after 2 minutes. The password was changed the day before, so the backup task is most likely still using the old password.

There was no successful login and no attempts from any other host. This is a setup problem, not an attack. I would still raise a ticket with the IT team so they update the stored password.

Verdict: False Positive

2. Suspicious PowerShell Started by Email Client

Severity	High
Description	PowerShell started by an Office application.
Host	LPT-FIN-014
User	R.Patel
Parent process	OUTLOOK.EXE
Command line	powershell.exe -nop -w hidden -enc SQBFAFgA...

The process tree was the main clue:

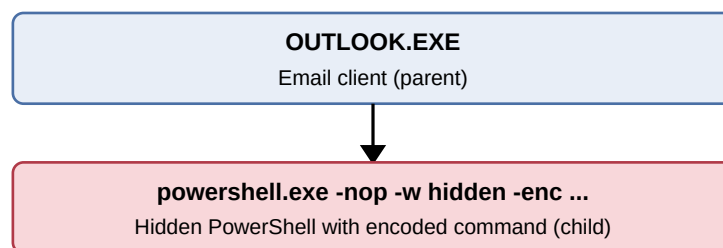


Figure 1. Process tree for example 2

Outlook should not start PowerShell during normal use. The command line has three red flags:

- -nop skips the user profile, so it runs without normal settings.
- -w hidden hides the window so the user does not see it.
- -enc means the command is encoded, which hides what it does from a quick look.

This looks like the user opened a malicious attachment. The device is a finance laptop, which raises the risk. I would escalate this straight away, ask for the laptop to be isolated, and check the user's mailbox for the email that caused it.

Verdict: True Positive

3. Payroll Email with Login Link

Severity	Medium
Description	Email from an external domain contains a link to a login page.
Subject	Action needed: confirm your bank details before payday
Sender	payroll@northfield-payroll.example
Real company domain	northfield.example
SPF / DKIM	Pass / Pass
Link	https://northfield-payroll.example/login

The sender domain looks like the company's own, but it has extra words added. This is called a lookalike domain. Attackers buy these so emails look real at a glance.

SPF and DKIM both passed. That only proves the email really came from northfield-payroll.example. It does not prove the domain is safe. The attacker owns that domain, so of course the checks pass.

The email also uses urgent language about payday and asks the user to log in through a link. Real payroll teams do not ask staff to confirm bank details this way. I would remove the email from all mailboxes, block the domain, and check if anyone clicked the link or entered details.

Verdict: True Positive

4. User Added to Domain Admins

Severity	High
Description	An account was added to the Domain Admins group.
Changed by	it.jsmith
Account added	temp-admin-migration
Host	DC-01
Time	14:10 on a weekday
Other context	Change ticket CHG-1042 approved a temporary admin account for a server migration

Adding someone to Domain Admins is a big deal, because that group controls the whole domain. Attackers often do this after they break in. So this alert needs a careful check.

The change was made by a known IT admin, during working hours, on the domain controller. It matches an approved change ticket with the same account name. This is expected activity. I would add a note to check that the account is removed when the migration ends.

Verdict: False Positive

Summary

Example	Verdict	Main clue
Multiple Failed Logins	False Positive	Matches the backup task after a password change
Suspicious PowerShell	True Positive	Outlook started hidden, encoded PowerShell
Payroll Email	True Positive	Lookalike domain with a login link
User Added to Domain Admins	False Positive	Matches an approved change ticket

What I Learned

While practising, I made a mistake with a phishing email. The sender address looked like a well known company, so I trusted it. I then learned that the sender address can be faked and proves nothing on its own. Example 3 shows the other side of this. Even when SPF and DKIM pass, the domain itself can belong to an attacker.

- An alert is something to check, not proof of an attack.
- Context like host names, networks and change tickets often explains an alert.
- Check who really sent an email, not just what the sender name says.
- Look at the process tree and ask if the parent should ever start that child process.
- A good comment says who was affected, what happened, the evidence and what should happen next.

Conclusion

This report shows the triage process I use and how I apply it to different types of alerts. Two of my examples were real attacks and two were normal activity. Getting a verdict right depends on checking the context, not just the alert name.